Security Architecture & Threat Model Report

Healthcare Appointment System

Task 1: System Definition and Architecture

Application Components

Frontend Portals

- Patient Portal: book/cancel appointments, view/search doctors based on speciality and availabilty, message doctors, login/signin, receive notifications
- Doctor Portal: manage schedules, manage availability, mark appointments as done
- Hospital/Admin Portal: manage staff, departments, billing, system config

Backend Services

- API backend: request routing and validation, handling all business logic: authentication, authorization, appointment scheduling, notifications,

Data Storage

- Patient Database: credentials, appointment history
- Doctor/Staff Database: credentials, schedules, specializations
- Secrets Vault: API keys, certificates, encryption keys

External Integrations

- Identity Provider: SSO/OAuth for staff authentication
- SMS/Email Gateway: appointment notifications

Users and Roles

Role	Description

Patient	Books appointments, views own records, messages doctor
Doctor	Views patient records, manages schedule, writes prescriptions
Hospital Admin	Manages staff accounts, departments, billing config
System Admin / DevOps	Deploys and maintains the platform
External: Insurance API	Automated claim submission and eligibility

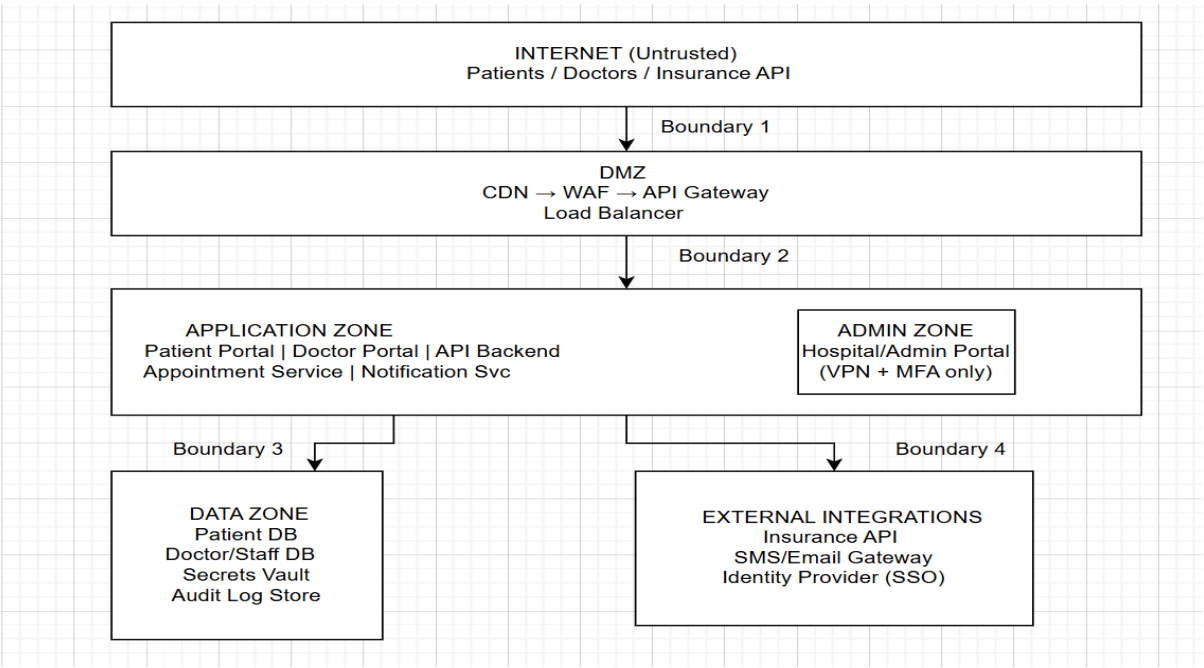
Data Types Handled

- Personally Identifiable Information (PII): names, dates of birth, contact details, national IDs
- Authentication Credentials: hashed passwords, session tokens, MFA seeds
- Appointment Records: schedules, doctor assignments, visit notes
- Audit Logs: all access and modification events across the platform

External Dependencies

- Email/SMS Gateway: outbound notifications only.

High-Level Architecture Diagram



Trust Boundaries

- **Boundary 1:**(Internet -> DMZ): All inbound traffic passes through CDN, WAF, and API Gateway. DDoS mitigation and input validation at this boundary.
- **Boundary 2:** (DMZ -> App Tier): TLS termination at load balancer; internal traffic re-encrypted with mTLS between services
- **Boundary 3:** Application Zone -> Data Zone : Database in isolated subnet; access only from API Backend service identity; all data encrypted at rest.
- **Boundary 4:** Application Zone -> External Integration Zone (mTLS, URL allowlisting, certificate pinning for the insurance API, etc.)
- **Boundary 5:** Admin Zone -> All Zones (VPN + MFA, most privileged)

Task 2: Asset Identification and Security Objectives

Asset Inventory Table

#	Asset	Type	Description
A1	Patient PII	Data	Names, DOB, national IDs, contact info
A2	Authentication Credentials	Data	Passwords, tokens, MFA seeds for all users
A3	Appointment Records	Data	Scheduling data, doctor assignments, visit notes
A4	Encryption Keys & Certificates	Data	Stored in Secrets Vault
A5	Doctor Credentials & Schedules	Data	profiles and working hours
A6	Appointment Service	System	Manages all scheduling logic
A7	Hospital Admin Portal	System	Full platform configuration access
A8	Insurance API Integration	Integration	Claims and eligibility channel
A9	Audit Logs	Data	Immutable record of all system events

A10	Notification Service	System	Sends PHI-adjacent appointment reminders

Assets Mapped to Security Objectives

Asset	Confidentiality	Integrity	Availability	Accountability
A1 – Patient PII	Critical	High	High	Critical
A2 – Auth Credentials	Critical	Critical	High	Critical
A3 – Appointment Records	High	Critical	Critical	High
A4 – Encryption Keys	Critical	Critical	Critical	Critical
A5 – Staff Credentials	Critical	High	High	Critical
A6 – Appointment Service	High	Critical	Critical	High
A7 – Admin Portal	Critical	Critical	High	Critical
A8 – Insurance API	Critical	Critical	High	High
A9 – Audit Logs	High	Critical	High	Critical
A10 – Notification Service	High	High	High	High

Task 3: Threat Modeling (STRIDE)

Threat Model Table

ID	Threat	STRIDE Category	Affected Component	Impact	Risk Level

T1	Attacker brute-forces patient login	Spoofing	Authentication Service	Account takeover, PHI exposure	**High**
T2	Doctor impersonates another doctor via IDOR	Spoofing	Medical Records Service	Unauthorized PHI access	**High**
T3	Patient accesses another patient's records	Spoofing / Elevation	API Gateway, Medical Records Svc	Privacy violation, HIPAA breach	**High**
T4	Appointment record altered to swap doctor or time	Tampering	Appointment Service	Care disruption, fraud	**High**
T5	Audit logs deleted by malicious insider	Tampering	Audit & Logging Service	Loss of forensic evidence, compliance failure	**High**
T6	PHI exposed in API error messages	Information Disclosure	API Gateway / Backend Services	Regulatory breach, patient privacy violation	**High**
T7	Notification emails contain PHI in plaintext	Information Disclosure	Notification Service	PHI exposure via email interception	**Medium**
T8	Insurance API keys leaked in source code	Information Disclosure	Insurance Integration	Fraudulent claims submission	**Medium**
T9	Appointment service taken offline (DoS)	Denial of Service	Appointment Service	Patients miss critical care appointments	**High**
T10	Admin portal accessible from public internet	Elevation of Privilege	Hospital Admin Portal	Full system compromise	**High**

T11	Session token hijacked via XSS on patient portal	Spoofing	Patient Portal, Auth Service	Patient account takeover, PHI access	**High**
T12	Insider copies bulk patient data before leaving	Information Disclosure	Patient DB, Medical Records Store	Mass PHI exfiltration	**High**

Task 4: Secure Architecture Design

Security Controls by Category

1. Identity and Access Management (IAM)

- **MFA enforced** for all users hardware tokens or authenticator apps required for doctors, admins; SMS-based MFA minimum for patients
- **Role-Based Access Control (RBAC) with Attribute-Based extensions:** Access to patient records limited to doctors with an active care relationship
- **Separate identity domains** for patients and doctors; admin identities managed through a hardened IdP
- **Short-lived session tokens** (30-minute expiry for clinical staff, 15-minute for admin) with secure refresh rotation
- **Break-glass access procedures** for emergency access to records, with mandatory post-access review and alerting
- **Account lockout, rate limiting, and CAPTCHA** on all login endpoints (mitigates T1, T11)

2. Network Segmentation

- **DMZ Layer:** WAF and API Gateway are the only internet-exposed components; all other services are on private subnets
- **Application Zone:** Backend services communicate via an internal service mesh with mutual TLS; no direct inter-service HTTP

- **Data Zone:** Patient DB, Doctor DB and Secrets Vault are on a separate private subnet with firewall rules permitting access only from specific application-zone service accounts
- **Admin Zone:** Hospital Admin Portal is accessible only via VPN with MFA; no internet-facing path exists (mitigates T10)

3. Data Protection

- **Encryption in transit:** TLS 1.3 enforced for all connections patient browser to API, service to service, and all external integrations
- **Encryption at rest:** All databases, backups, and file stores encrypted with AES-256
- **PHI minimization in notifications:** Appointment reminders contain no PHI only a booking reference and a secure link in emails or SMS (mitigates T7)
- **Database-level row access controls:** Queries for patient records are filtered server-side by patient ownership and care relationship application logic alone is not trusted (mitigates T3)

4. Secrets Management

- **Dedicated Secrets Vault** for all API keys, integration credentials, and encryption keys
- **No secrets in source code or environment variables** runtime injection from vault only
- **Automatic secret rotation** for all third-party integration keys
- **Vault access fully audited** every key retrieval is logged with service identity and timestamp (mitigates T8)

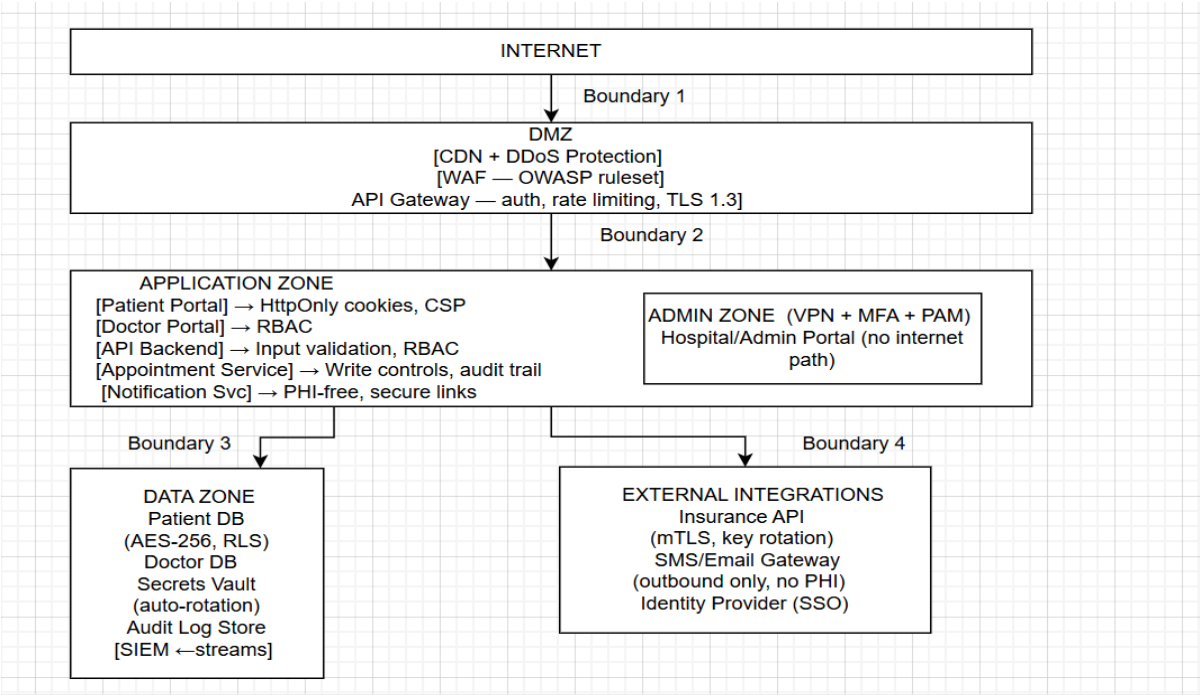
5. Monitoring and Logging

- **Centralized, write-only SIEM:** All services stream logs to an isolated logging infrastructure; no service has delete access to its own logs
- **PHI access auditing:** Every read or write of a patient record is logged with user identity, timestamp, and record accessed mandatory for HIPAA compliance
- **Anomaly detection alerts:** Triggered on bulk record access, access outside normal working hours, failed login spikes, and admin privilege changes
- **Break-glass access alerts:** Any emergency record access triggers an immediate notification to the privacy officer and a mandatory review workflow
- **Log integrity protection:** Hash-chained log entries to detect retroactive tampering

6. Secure Deployment Practices

- **Separation of duties in CI/CD:** No single engineer can approve and deploy their own code changes to production
- **Infrastructure as Code with security scanning:** All network configs and service definitions scanned for misconfigurations pre-deployment
- **Container vulnerability scanning:** All images scanned before deployment; base images regularly updated
- **No direct production database access for humans:** All schema changes via reviewed and audited migration scripts; DBA access requires dual approval
- **Regular HIPAA compliance audits and penetration testing**
- **Data Loss Prevention (DLP) controls:** Alerts triggered on bulk exports or large data transfers from the data zone (mitigates T12)

Updated Architecture with Controls



Task 5: Risk Treatment and Residual Risk

Risk Treatment Table

Threat ID	Threat Summary	Treatment	Action
T1	Brute-force patient login	Mitigate	Rate limiting, lockout, MFA
T2	Doctor IDOR on another doctor's patients	Mitigate	Server-side care-relationship validation
T3	Patient accesses another patient's records	Mitigate	Row-level DB access controls, RBAC
T4	Appointment record tampered	Mitigate	Immutable audit trail, write controls
T5	Audit logs deleted by insider	Mitigate	Write-only SIEM, hash-chained logs
T6	PHI in API error messages	Mitigate	Error sanitization, PHI masking layer
T7	PHI in notification emails	Mitigate	PHI-free notification design, secure links only
T8	Insurance API key in source code	Mitigate	Secrets vault, no env-var secrets
T9	Appointment service DoS	Mitigate+Transfer	Auto-scaling, DDoS protection; SLA with provider
T10	Admin portal on public internet	Mitigate	Admin portal on private network, VPN-only
T11	Session token hijacked via XSS	Mitigate	CSP headers, HttpOnly/Secure cookies, short TTL
T12	Insider bulk copies patient data	Mitigate + Transfer	DLP controls, access monitoring; cyber insurance

Residual Risks

1. Legitimate Clinician Misuse of Access A doctor with legitimate access to a patient's records could still misuse that access (e.g., viewing records out of curiosity or malice). Technical controls verify the care relationship exists but cannot verify the clinician's intent. This risk is *accepted* with compensating controls: PHI access logging, periodic access reviews, and a mandatory privacy policy agreement. Behavioral anomaly detection provides a partial detective control.

2. Regulatory and Legal Exposure from Data Breach Even with all technical controls in place, a successful breach exposes the organization to HIPAA fines, civil litigation, and reputational damage. This risk is *transferred* through cyber liability insurance and *mitigated* through a documented Incident Response Plan with pre-defined breach notification procedures meeting regulatory timelines.

Task 6: Final Architecture

System Overview

The Healthcare Appointment System is a cloud-hosted, multi-tier application processing for patients, doctors, and administration. It integrates with the hospital system. The system is subject and designed for internet-facing deployment with zero-trust networking principles.

Key Assumptions and Limitations

Assumption:

- The cloud provider's managed services (KMS, managed PostgreSQL, CDN) meet their stated security SLAs and compliance certifications.
- Developers follow secure coding guidelines and complete HIPAA and secure development training annually.
- Third-party integration partners maintain their own security posture per contractual obligations.

Limitation:

- Physical security of endpoints (patient devices, doctor workstations) is outside the scope of this architecture. Device management (MDM) is assumed to be handled separately.
- Social engineering and phishing attacks targeting users outside the system boundary are partially mitigated by MFA and security awareness training but cannot be fully prevented architecturally.

Summary of Security Posture

Domain	Control Strength
Identity & Access Management	Strong
Network Segmentation	Strong
Data Protection (PHI)	Strong
Secrets Management	Strong
Monitoring, Logging & HIPAA Audit	Strong
Availability & Patient Safety	Moderate
Third-Party Partner Risk	Residual
Insider Misuse of Legitimate Access	Residual